Zaki Response (7 سيستم · System 7) — Engineering Handover

Date: 27 October 2026 · **Code state:** `main` @ `b8a4a1e` (merge of PR #1) · **Language:** English, with Arabic product terms in parentheses. **Audience:** the engineer who takes this over. Assume you have never seen the repo, and that the previous sessions (human or AI) are not available to ask.

> How to read this document. Section 0 is one page: read it first. Section 4 is the work plan. Everything else is reference. Every claim names a file. Anything not checked against the code is marked **UNVERIFIED**. Risks are marked **RISK** and their corrections **FIX** (the owner's colour convention: risk in red, fix in orange, never remove a feature, teach around it).

0. Read this first (one page)

1. **What it is.** A multi-tenant (one `Workspace` per customer store) sales-and-replies platform for cash-on-delivery commerce in Syria/Jordan. Customers write on Facebook Messenger, Instagram, WhatsApp, Telegram or TikTok. An AI agent (الوكيل الذكي) answers using a persona (الشخصية), a knowledge base (المعرفة) and the product catalogue, can build an order draft, and staff can take over. Next.js 14 App Router, RTL Arabic, Prisma + PostgreSQL (pgvector), zod, Vitest.
2. **What was just done.** The whole navigation and flow was restructured for "smoothness": 26 tabs became 21, duplicate pages merged, every dead-end button fixed, Arabic labels everywhere, an in-site guide and a guided tour added. All of it is merged to `main` (PR #1 on the fork). 99 test files / 1,533 tests, typecheck, lint, secret scan and build all pass, and GitHub CI is green. Details: section 3.
3. **What was NOT done.** Nothing that was asked is half-built, but a full review (code structure, logic, calculations, permissions, security) was run **after** the restructure and found real defects that are **not fixed**. Section 4 is the plan. This document is the review's deliverable; no defect has been fixed yet.
4. **Two critical security defects.** (a) *Cross-tenant account takeover*: anyone can self-register, invite any existing user's email into their own workspace, and then set that user's global password (S-01). (b) *Server AI key leaks*: a workspace can point the `hermes` provider at an attacker URL and the platform-wide `HERMES_API_KEY` is sent there (S-02). **Do not put real customers on a public deployment until S-01, S-02, S-03 and S-11 are fixed.**
5. **Two critical money/behaviour defects.** The yes/no parser misreads everyday Arabic: «يلا أكد الطلب» cancels the cart and «أي لون عندكم؟» places an order (L-01; I reproduced this). Quantity words are matched as substrings, so «بدي عشرين» means 10 and «الاثنين» (Monday) means 2 (L-02), and a chat can rewrite a placed order's quantity with no rules and no confirmation (L-03).
6. **The project's own rule files are partly stale.** `AGENTS.md`, `docs/INTEGRATIONS.md`, `docs/OMS-DOOR-V1.md` and `contracts/README.md` describe the OMS module, the agent door and signed OMS events as live. They were **deleted** on 2026-10-18 (commit `3c3c4aa`, "AI-only response system"). Trust the code, not those files, for anything OMS/agent-door. Fixing the docs is task D-01.
7. **The handoff queue is always empty.** The same commit made the AI never create a human handoff (`HumanHandoff`), and no production code calls `createHandoff` (only tests do). The page `/handoffs` ("تحتاج موظف") and the dashboard KPI "يحتاج موظف" therefore show nothing. This is a product decision for the owner (section 4.5, OD-1).
8. **The running site on `localhost:3250` is an old build** (from `C:\Users\LOQ\Documents\AIresponse-work\AIresponse`, 6 commits behind). It does not contain the restructure. Rebuild from this tree to see it.
9. **Account situation.** The restructure lives on `iahmed30004000-wq/AIresponse` (private). The canonical repo `MKory18/AIresponse` (public) does **not** have it yet. Section 1.
10. **Working rules that cannot be broken:** branch + pull request, never push to `main`; a test that fails before and passes after every fix; all five gates green; CI is the judge. Section 10.

1. Accounts, repositories, links

What	Where	Notes
Fork with the restructure (private)	https://github.com/iahmed30004000-wq/AIresponse	`origin` in the Desktop clone. PR #1 merged here: https://github.com/iahmed30004000-wq/AIresponse/pull/1 (merge commit `b8a4a1e`). CI green on it.
Canonical repo (public)	https://github.com/MKory18/AIresponse	Remote `mkory18`. `main` is at `2052c26` (docs-only PR #32). **Lacks PR #1.**
OMS / CRM (a different system)	https://github.com/MKory18/Zaki-ai-CRM	The only source of truth for the OMS. Two copies exist (`MKory18/zaki-ai-OSM-1`, `iahmed30004000-wq/zaki-ai-OSM`); treat them as read-only backups.
Local working copy	`C:\Users\LOQ\Desktop\AIresponse`	Clean, `main` tracks `origin/main`.

What	Where	Notes
Older local copy that feeds the running Docker stack	`C:\Users\LOQ\Documents\AIresponse-work\AIresponse`	Project name `airesponse`, ports 3250 (app), 5433 (postgres). 6 commits behind.

Open pull request on the canonical repo: `MKory18/AIresponse#25` "feat(ai): OPENAI_BASE_URL — external OpenAI-compatible gateway" (branch `feat/custom-openai-base-url`, last updated 2026-10-19). It touches `settings/ai/page.tsx`, `ai/status/route.ts`, `ai/providers/test/route.ts`, `ai/router.ts`, `ai/provider.ts`, `core/env.ts` and `knowledge/embeddings.ts`. **The restructure rewrote `settings/ai/page.tsx` and added `settings/ai/ai-status-card.tsx`, and S-02/S-08 below also change `router.ts` and the providers test route, so expect conflicts.** Merge status is `UNKNOWN`. Decide first whether #25 still wanted; if yes, rebase it onto the new `main` after S-02.

Moving the work to the next account (the owner plans to hand over). From the Desktop clone:

```
git remote add newowner https://github.com/<NEW-ACCOUNT>/AIresponse.git   # after creating the empty repo
git push newowner main
```

Create the repo as **Private**. Never push secrets: `.env`, `.env.local`, `docker-compose.override.yml` are git-ignored and exist only on the owner's machine. Re-create them from `.env.example` (section 9). After the move, update the repo table in `AGENTS.md` (task D-01) and re-check that CI runs (`.github/workflows/ci.yml`, two jobs).

Commit attribution used so far: commits end with `Co-Authored-By: Claude Opus 5.5 <noreply@anthropic.com>`; PR bodies end with 🤖 `Generated with [Claude Code](https://claude.com/claude-code)`. Keep or drop this by your own policy.

---

2. The owner's rules (digest of `AGENTS.md`, with stale parts flagged)

`AGENTS.md` is the single rules file (Claude Code reads it through `CLAUDE.md` → `@AGENTS.md`; opencode/GLM reads it directly). Read it in full. Digest:

Owner rules (mandatory).

- Reply to the owner in Jordanian Arabic, direct result, no internal steps. The owner is not a programmer.
- Anything risky or automated: red note with the risk, orange fix underneath. UI components `RiskNote` / `FixNote` / `RiskWithFix` in `src/components/integrations/ui.tsx`; in docs ⚠️ red and 🔧 orange. Never delete a feature; teach around it.
- Do not rebuild what already works. Search the code before adding anything.
- No customer data (name, phone, address) to any external model. Ad tokens never reach any model. No financial approvals from Telegram.
- B2B messages: no prices, never the word "package". Dashboards and reports: **no taxes**, and **every KPI states its calculation rule** (the KPI catalogue is in section 7).
- Owner deliverables are written as `.docx` + PDF (he reads on the phone).
- Every change: a test that fails before and passes after; never break existing behaviour.

Workflow. Plan (Claude Opus in chat) → build (GLM via opencode, on a **new branch**) → PR → CI (typecheck, lint, test, secrets, build, and a real-Postgres migration job) → review by Claude Code on the same branch → merge after green CI and a last human look. One agent per branch; before any work `git fetch origin && git merge origin/main`; a PR with conflicts never triggers CI; "green on my machine" is not enough, CI decides.

Invariants that must not break (each is guarded by a test): nav entries and search keywords and page guides for every dashboard page; old routes keep working; theme colours only from CSS variables (no hex in components or `tailwind.config.ts`); every secret field uses `PasswordInput` (no raw `type="password"`); every empty list points to the next step (`EmptyNext`); the visible UI never says "Hermes"; `CUSTOMER_INBOUND` media must pass `excludeCustomerInbound()`; idempotency keys include the workspace; SENT/DELIVERED/READ are final for an idempotency key; Prisma schema changes are additive migrations only.

Stale or false statements in `AGENTS.md` today (verified against the code):

`AGENTS.md` says	Reality on `main`
`src/modules/oms/` (webhook, manual link, handoff…) is live	Deleted in `3c3c4aa` (2026-10-18). No OMS code exists.
`src/modules/agent-door/`, `/api/agent/tools`, `/api/agent/call`	Deleted. No agent door.
`/api/webhooks/oms/[key]`, `/api/integrations/*`, pages `settings/integrations`, `settings/agents`	Deleted. `src/app/(dashboard)/settings/` now has only `account`, `ai`, `team`.
`contracts/oms-app-events.v1/` and `tests/contracts-*.test.ts`	Deleted. `contracts/` holds only a stale `README.md`.
`isHermesSelected`, `isHermesPersonaMode`, `hermes-diagnostics.ts`	Do not exist. The Hermes **provider** was removed then re-added in `737e9f8` and lives in `src/modules/ai/provider.ts`, `router.ts`, `core/env.ts`.
"Pending: PR #1 (P12 + Hermes)"	Obsolete.
README: "210 tests", "Facebook only"	1,533 tests; five channels exist (Facebook, Instagram, WhatsApp, Telegram, TikTok-stub).
Handoffs: "AI hands over to staff"	The AI never creates handoffs since `3c3c4aa`.

What survives of the ecosystem work (P12): the signed outbound system in `src/modules/integrations/*` (still run by the worker every cycle), `/api/v1/*` routes, Prisma tables `IntegrationConnection/Token/Delivery`, `OmsConnection`, `AgentDraft`, `AgentCallLog` (kept because migrations are additive-only). There is **no UI or API to create an integration token or connection**, so all of it is dormant (section 8).

---

3. What was done in this session (PR #1) — and what changed for users

Goal given by the owner: "smoothness above all; no complexity; each step leads to the next; clear in-site explanations; merge or delete duplicate and useless fields, buttons and pages; create what is missing." Five commits (`4ad1721`, `3e60d29`, `8cf937d`, `67fe97b`, `ad93bc6`), 54 files, +2,139 / −1,433.

3.1 Navigation: 26 tabs → 21, no broken link

Source of truth: `src/lib/nav-model.ts` (`NAV_GROUPS`, 7 groups). Old paths still work through `NAV_REDIRECTS` (small pages that call `redirectToMerged` in `src/lib/nav-redirect.ts`). **Do not delete the redirect pages.**

Group (المجموعة)	Tabs (path · required permission)
الرئيسية Home	`/dashboard` · analytics.read
المحادثات Chats	`/conversations` · conversations.read · `/handoffs` · handoffs.read · `/customers` · customers.read · `/intelligence` · conversations.read
المبيعات Sales	`/orders` · orders.read · `/products` · products.read · `/catalogs` · catalogs.read · `/campaigns` · campaigns.read
الوكيل الذكي AI	`/personas` · `/knowledge` · `/media` · `/feedback` · `/ai/playground` (التجربة) · `/settings/ai` (التشغيل)
الأتمتة Automation	`/automation` · `/follow-ups`
التقارير Reports	`/analytics` (tabs inside, `?tab=`)
الإعدادات Settings	`/channels` · `/settings/team` (users.manage) · `/settings/account` (no permission)

Old path	Now
`/order-warehouse`	→ `/orders`
`/ai/studio`	→ `/settings/ai`

Old path	Now
`/workflows`	→ `/automation` (one merged list of quick rules and step workflows)
`/analytics/ai`, `/analytics/products`	→ `/analytics?tab=ai` / `?tab=products`
`/settings`	→ `/settings/account`

3.2 Guidance (the "explanation inside the site")

- **Setup checklist "ابدأ من هون"** (`src/modules/setup/progress.ts`, `GET /api/setup/progress`, `components/setup-checklist.tsx`): 6 steps in order — channel → products → persona → knowledge (new step, optional: an active FAQ or a READY document) → playground → go-live (`/settings/ai`).
- **Page guides** (`src/lib/page-guides.ts`): every page has "what is this page" + "next step" pointing to another nav page, forming one chain (`/channels` → products → personas → knowledge → playground → `/settings/ai` → conversations → handoffs → customers → orders → analytics). First visit opens the panel automatically.
- **Guided tour** (`src/lib/guided-tour.ts` = step data, `src/components/guided-tour.ts` = runner): 10 steps on elements tagged `data-tour`; runs once on first `/dashboard` visit (localStorage key `zr-tour-seen`) and from a compass button in the top bar. Library: **driver.js 1.9.0**, MIT, pinned exactly (chosen because the version is more than two weeks old). Styles in `globals.css` under `.zr-tour`, built from theme tokens.

3.3 Merged / rebuilt pages

- **AI settings** (`settings/ai/page.tsx` + new `ai-status-card.tsx`): a status headline at the top (stopped / missing provider / auto-reply off / agent replying on its own), then "التشغيل" toggles, "الاتصال", and an "متقدّم" block (models with Arabic task names, creativity, max reply length, fallback). The two unused confidence fields are no longer shown (still sent on save).
- **Automation** (`automation/page.tsx` rewritten + `quick-rule-dialog.tsx`, `workflow-builder-dialog.tsx`): one list from `GET /api/workflows`; states مسودة / موقوفة / شغّالة; quick rules toggle on/off; step workflows have simulate (محاكاة), publish (تشغيل), pause, stop-and-cancel. Delete via `/api/automations/:id`. Both engines share the `automation` table (see finding L-14).
- **Reports** (`analytics/page.tsx`): title "التقارير"; new products tab; `?tab=` deep links; export button only on tabs with an export; time zones from `src/lib/timezones.ts`.
- **Personas**: the broken in-page preview (it called an endpoint that returns 410) was replaced by a "جرّبها" link to `/ai/playground?persona=<id>`, which preselects the persona.
- **Campaigns**: segments are step ١, campaign form step ٢; new `segment-dialog.tsx` with ready presets (consent, buyers, never ordered, recent, dormant, frequency cap) posting a closed-schema segment; "معاينة بلا إرسال" replaces "Dry-Run".
- **Dead ends removed**: handoffs → `/conversations?id=`; customers (mobile) → `/conversations?q=`; orders linked from the customer panel; order page shows Arabic totals and a "كل الطلبات" back link; knowledge/media empty states have real buttons; `GET /api/faqs` added (the page called it, only POST existed → "failed to load knowledge" every time).
- **Arabic everywhere**: ~60 new entries in `LABELS` (`src/lib/i18n.ts`) so no status or category shows as raw English; `tests/labels-arabic.test.ts` parses the Prisma enums and fails if a displayed enum value has no Arabic label.
- **Team menu**: hidden from users who cannot open it.

3.4 Tests added/changed

New: `faqs-list-route`, `smooth-flow` (includes segment-preset schema validity), `labels-arabic`, `guided-tour`. Updated: `nav-structure` (21 tabs, redirects), `page-guides`, `nav-search`, `empty-next`, `setup-progress` (6 steps), `provider-labels`, `persona-management`. Result: **99 files / 1,533 tests** (baseline before: 1,493).

3.5 Things deliberately left alone (small, known, not blocking)

- Knowledge: an archived document cannot be restored from the UI (API supports it); FAQs cannot be edited or deleted from the UI (there is `PATCH /api/faqs/[id]` but no `DELETE`).
- Personas: a draft version's text cannot be edited before publishing; a step-workflow draft cannot be edited in place.
- Handoffs list shows the employee's internal id (`assignedTo`) instead of a name.
- Campaigns: an error from one campaign's action shows in the new-campaign form (`formError` is shared); the sending log can show under a different campaign than the one opened.
- These are task U-01…U-04 in section 4.

---

4. The work plan (what the next engineer must finish)

4.0 How to work through it

- One branch per task (or tight group), PR into `main`, CI green, then merge. Order: **Phase 0** → **1** → **2**; Phase 3 needs owner decisions; Phase 4 can run in parallel.
- **Test first**: write the failing regression test (the "Test" column), watch it fail, fix, watch it pass. Fixtures: `tests/helpers/inmemory-db.ts` (`createFakeDb()`); route tests mock `@/modules/auth/context` and `@/core/db/prisma` — copy the pattern in `tests/faqs-list-route.test.ts`.
- Size: S ≈ hours, M ≈ a day, L ≈ several days (judgement, not measured).
- Verification status: **V** = I read the code path myself (and ran it where noted); **R** = reported by a specialised reviewer who read the code path end to end, not independently re-run. Treat R as "very likely", and confirm with the test before fixing.

4.1 Phase 0 — blockers before any real customer (security + order integrity)

ID	Sev	Where	Problem and exploit	Fix	Test	Size	Status
S-01	Critical	`src/modules/members/service.ts` `resetMemberPassword` (≈L405), `updateMember` (≈L248); route `api/workspaces/members/[id]/route.ts`	`User` is global across workspaces. A `users.manage` holder overwrites `passwordHash` of any user that has a membership row in *their* workspace — including a row in `INVITED` status, and without checking the user's role in other workspaces. Attack: register (public) → become OWNER of own workspace → `POST /api/workspaces/members {email: victim}` creates an `INVITED` row (201 vs 404 also leaks whether an email is registered) → `PATCH …/members/{id} {newPassword}` → log in as the victim, possibly an OWNER elsewhere. Also `updateMember` lets `status:"ACTIVE"` force-accept an invite (H1).	Allow admin reset only for ACTIVE members who have **no membership in any other workspace** (or accounts created by `createMember` in this workspace); else 403 `USER_SHARED_ACROSS_WORKSPACES`. Forbid `INVITED→ACTIVE` in `updateMember` (only `acceptInvite` may). Return a generic response on invite.	New `tests/member-password-reset-isolation.test.ts`: owner A invites owner B → reset 403, B's hash unchanged; reset of an INVITED row 403; reset of a member shared with another workspace 403; PATCH status ACTIVE on INVITED → 422.	M	**V** (code read: no status/cross-workspace check; invite creates INVITED row)
S-02	Critical	`src/modules/ai/router.ts` ≈L365–381 (hermes branch); `api/ai/providers/test/route.ts`; `api/ai/settings/route.ts`	With `provider="hermes"`, a workspace `customBaseUrl` overrides `HERMES_BASE_URL` but the request still sends the platform-wide `HERMES_API_KEY`. Only openai/openrouter got the key-exfiltration guard (OCR-2026-10-16). Any self-registered OWNER (has `ai.configure`): PATCH settings to `https://evil.example/v1`, press "test connection": the key leaves the server, and later every masked prompt.	Never attach an env key to a workspace URL. Either ignore `customBaseUrl` for hermes or require its host to equal `HERMES_BASE_URL`'s host; otherwise demand a workspace-stored key (as the `custom` provider does).	New `tests/hermes-key-exfil.test.ts`: `getWorkspaceProvider({provider:"hermes",customBaseUrl:"https://evil.example"})` throws or sends no env key; assert on a mocked `fetch`'s headers.	S	**V** (code read)
S-03	High	`src/modules/auth/session.ts` `verifySessionToken`; `channels/facebook/oauth.ts`; `api/channels/facebook/callback/route.ts`	`verifySessionToken` accepts **any** HS256 JWT signed with `JWT_SECRET` that has a string `userId`. The Facebook OAuth `state` and `fb_pages` tokens carry `userId` + `workspaceId` (and a `kind`), so each is a valid 10-minute **session** cookie for whoever sees the URL (logs, history, Meta). The `fb_pages` JWT is signed not encrypted and carries every page's long-lived access token in the URL.	Add `kind:"session"` when signing and require it in `verifySessionToken`; keep page tokens server-side (short-lived DB row or encrypted JWE) and put an opaque id in the URL.	New `tests/session-token-kind.test.ts` (OAuth state/pages token → `null`); `tests/fb-oauth-selection-token.test.ts` (no `accessToken` in the decoded URL token).	M	**V** (code read: `kind` checked only in oauth verifiers, not in session verifier)

ID	Sev	Where	Problem and exploit	Fix	Test	Size	Status
S-04	High	`src/modules/media/service.ts` `updateMedia` (≈L182–202)	No `CUSTOMER_INBOUND` guard (`attachProductMedia` has one). A `media.write` user can PATCH a customer's inbound photo to category PRODUCT/set `productId`; it then appears in the library, gets public URLs and goes to other customers/the AI. Breaks the owner privacy invariant.	Reject any update that changes category/`productId` of a `CUSTOMER_INBOUND` asset (allow only title or nothing).	Extend `tests/wa-media-privacy.test.ts`.	S	R
S-05	High	`src/modules/products/service.ts` (list/detail); routes `api/products*`	Full product rows (`wholesalePrice`, `discountCap`) go to anyone with `products.read` (VIEWER, SALES_AGENT, SUPPORT_AGENT), bypassing the declared `products.wholesale` permission (`pricing-policy.ts`, role matrix).	Shared serializer: strip both fields unless `auth.can("products.wholesale")`, used by list and detail.	`tests/products-wholesale-visibility.test.ts`.	S	R (two reviewers independently)
S-06	High	`src/app/api/auth/register/route.ts`; `prisma/seed.ts` L4–5; `docs/COOLIFY-STAGING.md` §12	Public self-registration creates a new workspace for anyone (can run up platform AI keys, enumerate emails via 409). The seed has no production guard and creates `admin@demo.local` with a hard-coded published password as OWNER of a connected demo workspace; the deploy doc tells you to run it.	`ALLOW_SIGNUP` env (default **off** in production) or invite-gate after the first owner; generic error responses. Seed refuses when `NODE_ENV=production` unless `ALLOW_DEMO_SEED=1`; fix the COOLIFY doc.	Register returns 403 when the flag is off; seed exits non-zero in production.	S	R
L-01	Critical	`src/modules/orders/primitives.ts` L103–119 (`parseConfirmation`), used by `orders/intelligence.ts`	`NO_PATTERNS` is an unanchored substring match, checked first, so any word ending in «لا» is "no"; `YES_PATTERNS` treats «أي/اي» at the start as "yes". With a READY draft: «يلا أكد الطلب» → NO (cart cancelled); «أهلا» → NO; «أي لون عندكم؟» → **YES (order created)**.	Match whole tokens only; accept «أي/اي» only as the entire message; if both yes and no match return NONE.	Table test: those three strings → YES / NONE / NONE.	S	**V** (I ran the parser: `يلا أكد الطلب => NO`, `أهلا => NO`, `أي لون عندكم؟ => YES`)
L-02	High	`primitives.ts` ≈L289–293 (`parseQuantity` number words)	Number words matched as substrings in insertion order: «بدي عشرين قطعة» → 6 → «عندي استفسار» → 2, «يوم الاثنين» → 3, «ثلاثين» → 10,	Match whole tokens; add tens (عشرين…تسعين, مية); never read a number from inside a longer word.	Table test with these four inputs.	S	R (reviewer ran the parser)
L-03	High	`orders/order-service.ts` `updateOrderFromChat` (≈L408–434) from `orders/intelligence.ts`	Editing a **placed order** from chat skips every order rule: no `MAX_ORDER_QUANTITY`, no stock/active check, no customer confirmation; totals rewritten immediately. With L-02 a wrong number silently changes an order (1→5000 or →2).	Run `evaluateOrderRules` before the edit and route the edit through a confirm step like a draft.	Edit quantity 101 → `EXCEEDS_MAX`, order unchanged.	M	R
D-01	High	`AGENTS.md`, `docs/INTEGRATIONS.md`, `docs/OMS-DOOR-V1.md`, `contracts/README.md`, `README.md`	Rules describe deleted code (section 2). A new engineer or AI agent will build on things that do not exist.	Rewrite the integration map and "pending" lists to match the code; move OMS-door notes under "future". Keep owner rules untouched.	—	S	**V**
O-01	High	deployment	**No backups exist** (no `pg_dump` job; volumes `pgdata`, `storage` local only).	Scheduled `pg_dump` + storage copy off-host; restore drill.	restore rehearsal	M	R

4.2 Phase 1 — money and numbers correctness

ID	Sev	Where	Problem (example)	Fix / Test	Size
L-04	High	`sales/plan-builder.ts` → `orders/order-service.ts` L87–92, `pricing.ts`	Offer ("3 for 50,000", unit 20,000) is shown to the customer, but the order is always `unitPrice × qty` → 60,000 and `OFFER_ACCEPTED` is still recorded. Apply the matched offer in `calculatePricing`; test `total === 50000 + fee`.	as in Problem	M
L-05	High	`sales/pricing-policy.ts` L248–271, `coach.ts` L131–150	Approved discounts are never applied (`useDiscountApproval` has no production caller); the Coach prints a ready text "price becomes 18,000" even when approval is still required; the order is created at 20,000. Accept an `approvalId` at order creation/edit; hide `draftText` while `requiresApproval`.	as in Problem	M
L-06	High	`pricing-policy.ts` L194–220	Approval `expiresAt` is set at request time (+24h) and **not reset on approval**; an expired PENDING request can still be approved. Set `expiresAt = now+TTL` on approval; refuse approving an expired one.	as in Problem	S
L-07	High	`automation/engine.ts` L220–237, L175; `workflow-engine.ts` L418–424; `followup-service.ts` L128	Rule "CHANGE_AI_STATE → AI_ACTIVE" overrides a human takeover (HUMAN_ACTIVE); quick-rule `SEND_MESSAGE` and the follow-up sender also send during HUMAN_ACTIVE. Violates "HUMAN_ACTIVE ⇒ zero automated replies". Re-read state at execution time and skip.	as in Problem	M
L-08	High	`analytics/service.ts` L63–64, 179–196, 248; `aggregation.ts` L190–193; `agents.ts` L152	Every money total adds `Number(total)` **across currencies** (USD 20 + SYP 150,000 = "150,020"). Group by currency, show each with its code.	as in Problem	M
L-09	Medium	`orders/delivery.ts` L178–207, `pricing.ts` L53	`DeliveryRule.fee` / `freeOver` have no currency; a USD product + a fee configured in SYP adds 15,000 to 20. Add currency to the rule; refuse mismatches.	as in Problem	M
L-10	Medium	`order-service.ts` L435–451	Province-only edit sets `total = item.subtotal + fee`, ignoring discount and other items (100−10+8 should be 98, gives 108).	as in Problem	S
L-11	Medium	`campaigns/segment-service.ts` L75, 103, 117	`noReply` / `notReceivedWithinDays` add an empty filter that matches everyone; under `match:"ANY"` the segment becomes **every customer**. Evaluate per customer or reject under ANY.	as in Problem	M
L-12	Medium	`segment-service.ts` L142–188; `campaign-runner.ts` L80–86	Audience is cut to the oldest 5,000 candidates **before** the consent filter, so a campaign can fail `EMPTY_AUDIENCE` while 1,000 opted-in customers exist; `truncated` ignored. Filter consent in the query.	as in Problem	M
L-13	Medium	`order-service.ts` L332–338 vs engines	Real order cancellations never fire ORDER_CANCELLED rules, and scheduled follow-ups are not cancelled when the order is cancelled or the customer replies. Publish `OrderCancelled{orderId,customerId,conversationId}`; skip due follow-ups for cancelled orders.	as in Problem	M
L-14	Medium	`automation/engine.ts` L82–85; `workflow-engine.ts` L525–531; `api/automations/[id]/route.ts`	Both engines share the `automation` table and each runs the other's rows (phantom FAILED/SKIPPED executions: 10 orders → 40 execution rows instead of 20). The workflow engine reads the live row (no `versionId` column), and `/api/automations` can enable/duplicate/edit workflows with no publish step. Add a `kind` column; make `/api/automations` refuse workflow rows.	as in Problem	L
L-15	Medium	`order-service.ts` L486–492	Chat «ألغِ» cancels the newest *cancellable* order of the last 5 even if the newest is already delivered. Target only the newest order.	as in Problem	S
L-16	Medium	`dashboard/page.tsx` L96–99	"التحويل" = confirmed orders created in range ÷ conversations created in range (different populations; 10 conversations + 15 orders from old chats = 150%). Count distinct new conversations that have a confirmed order.	as in Problem	S
L-17	Medium	`analytics/service.ts` L390–414	Funnel counts drafts by *current* state; the single draft row per conversation is recycled after conversion, so "ready" drops to 0 while orders confirmed is 5. Count from audit events.	as in Problem	M
L-18	Medium	`analytics/trends.ts` L258–316 + `aggregation.ts` L87–91	Rebuild is enqueued with `to=lastDay` but the builder stops before its end date → "today" is always MISSING and a full rebuild is re-enqueued on every view; STALE rows hidden by the UI. Enqueue `to = lastDay + 1 day`; rebuild STALE; show a badge.	as in Problem	M
L-19	Medium	`analytics/page.tsx` L196, `dashboard/page.tsx` L75	Time zone defaults to UTC, ignoring `Workspace.timezone`; an order at 01:30 Damascus lands on the previous day.	as in Problem	S

ID	Sev	Where	Problem (example)	Fix / Test	Size
L-20	Medium	`analytics/service.ts` L440–462	SLA breach rate counts only answered conversations (5 fast, 5 never answered → 0%). Count unanswered older than the SLA as breached.	as in Problem	S
L-21	Low	`analytics/service.ts` L12, 34, 151–152	"Resolved/resolution time" use `conversation.updatedAt`; any later tag edit stretches it (30 min → ~4,320 min). Add `resolvedAt`.	as in Problem	M
L-22	Low	`analytics/service.ts` L276–289	Per-model cost depends on row order for null/0. Return `{known, unknownCalls}`.	as in Problem	S
L-23	Low	`sales/metrics.ts` L126–131	`offerAcceptRate` has no time window or dedupe (1 show + 2 orders = 200%).	as in Problem	S
L-24	Low	`analytics/page.tsx` L173–180	Previous-period comparison window not aligned to days.	as in Problem	S

Note for L-04/L-05: both are "feature advertised but not applied" gaps in the sales engine (P8). Decide with the owner whether to implement or to hide the advertised text; do not leave them half-wired.

4.3 Phase 2 — security hardening

ID	Sev	Where	Problem	Fix / Test	Size	Status
S-07	High (owner decision)	`intelligence/service.ts` ≈L197, `intelligence/provider.ts`; trigger `conversations/inbound.ts` ≈L330	The data-collection lab (مختبر التجميع; channels in `COLLECTION_ONLY` mode) sends the last 8 **raw customer messages** — names, phones, addresses — straight to OpenRouter with the platform key, bypassing the privacy gate. Contradicts the owner rule.	Allow extraction only on an internal/self-hosted provider, or extract locally; fail closed when only an external provider exists. Test: stubbed fetch sees no raw PII.	M	V (provider calls `generateStructured` directly; OpenRouter only)
S-08	High (owner decision)	`ai/stages/extraction.ts` ≈L127, `response.ts` ≈L180, `jobs/handlers.ts` ≈L310, `ai/privacy-gate.ts` ≈L375	The privacy gate masks only PII already stored in the DB plus phone/email regex. A new customer's free text ("ابعتوه لأبو أحمد، حي الزهور شارع 5") reaches an external model unmasked at extraction, response and summary. The 2026-10-19 fix report says "sensitive stages restricted to trusted provider"; **no such check exists on `main`**.	Owner decision: restrict those stages to internal providers, or add name/address heuristics, fail-closed.	M–L	R
S-09	Medium	`api/ai/settings/route.ts` L63–101; `router.ts` L385–407	Switching provider skips the URL guard (it runs only when `customBaseUrl` is in the request, judged by the provider at that moment). `internal` then reuses a stored URL with no call-time check, follows redirects, and `delivery:"internal"` turns masking off. A LAN URL saved under hermes (with the private-network flags) then `provider:"internal"` reaches the LAN; a public "internal" URL gets unmasked prompts.	Re-validate the stored URL on every provider change and in `getWorkspaceProvider`; `followRedirects:false`; treat any workspace-supplied URL as `external` (masked) unless env declares it trusted.	M	R
S-10	Low (functional)	`ai/endpoint-guard.ts` L223–224	The default parameter named `lookup` shadows the imported `lookup` and calls itself → `RangeError` → every hostname save/probe for openai/openrouter/internal fails with `DNS_RESOLUTION_FAILED` in production (tests inject a lookup so they miss it). Rename and call the real `lookup`.	as in Problem	S	V (code read)
S-11	Medium	`core/api/handler.ts` L59, L82–86; `docker-compose.yml` L18/22	Rate-limit key is the leftmost `X-Forwarded-For` (client-controlled); app published on 3000 with no proxy. Rotating XFF = unlimited login/register/jobs attempts; requests with no XFF share one `"local"` bucket (10 logins/min lock everyone out). Severity depends on the proxy: if one overwrites XFF it is Low.	Take the client IP from a trusted hop (configurable); add a per-email login limiter; do not publish 3000 publicly. Test: 11 logins, different XFF, same email → 429.	M	R (needs-confirmation: topology)

ID	Sev	Where	Problem	Fix / Test	Size	Status
S-12	Medium	`api/auth/*`, `session.ts`	JWTs cannot be revoked: logout only deletes the cookie, a password change/reset does not invalidate existing tokens (7-day TTL).	`User.sessionVersion` (or `passwordChangedAt`) in the token, checked in `getAuthContext`; bump on change/reset/logout-all.	M	R
S-13	Medium	`api/webhooks/{meta,whatsapp,instagram,telegram,tiktok}`, `v1/webhooks/[system]`; `telegram/webhook.ts` L34–55	Webhook bodies are read with `req.text()` with no cap (`createHandler` checks only `Content-Length`, which chunked requests skip). Telegram decrypts **every** account's secret per request (O(n)) before authenticating.	Stream with a ~1 MB hard cap before the HMAC; route Telegram by a per-channel id.	M	R
S-14	Low	`telegram/normalizer.ts` L75–79, `tiktok/normalizer.ts` L58–64	Idempotency keys (`tg:update:<n>`, `tt:…`) lack the workspace — violates the `AGENTS.md` rule; one tenant can pre-insert ids and drop another's updates. Add channel/workspace to the key.	as in Problem	S	R
S-15	Low	`core/logger.ts` L5–17	Pino redaction is top-level only; nested `*.token`, `*.apiKey`, `*.headers.authorization` would be logged.	as in Problem	S	R
S-16	Low	`api/analytics/rebuild/route.ts` L25–31	Target workspace membership checked for existence only, not `ACTIVE`; authority is `settings.manage` of the *current* workspace.	as in Problem	S	R
S-17	Low	`automation/engine.ts` L212–218	`ASSIGN_CONVERSATION` writes `agentId` without the active-member check (`workflow-engine.ts` L390 has it).	as in Problem	S	R
S-18	Low	`api/handoffs/[id]/route.ts` L24–37	`release`/`route` need only `handoffs.claim`: any agent can un-claim a colleague's handoff or re-route the queue; `resolve` also uses `claim`.	as in Problem	S	R
S-19	Low	`campaigns/campaign-service.ts` L126–133	After approval, editing `channelId`, `ratePerMinute`, `timezone` does not reset approval (only content edits do).	as in Problem	S	R
S-20	Low	`ai/playground-service.ts` L110–113	`assertWorkspaceOwned("channel")` omits the workspace check (existence oracle for another tenant's channel id).	as in Problem	S	R
S-21	Low	`products/import-service.ts` L109; `knowledge/extract.ts`; `knowledge/upload/route.ts`	exceljs parses a zip-bomb sheet before the row cap; `pdf-parse` 1.1.1 runs synchronously in the web process without timeout; whole upload buffered before the size check.	as in Problem	M	R
S-22	Low	`core/crypto.ts`; `next.config.mjs`; `media/public/[token]`; `whatsapp/client.ts` L213–233	One `ENCRYPTION_KEY` for AES-GCM and media-token HMAC (no key separation); no HSTS; public media route does not re-check `CUSTOMER_INBOUND` at serve time; media download buffers whole body despite the comment.	as in Problem	S each	R
S-23	Info	`next.config.mjs` L19	CSP still has `script-src 'unsafe-inline'` (old finding F-006, open).	as in Problem	M	R

ID	Sev	Where	Problem	Fix / Test	Size	Status
UX-1	Low	`components/inbox/inbox.tsx` and most client pages	The UI never learns the user's permissions: a VIEWER sees composer, takeover, create/edit buttons that all return 403 (only the order page gets `canWrite`). The layout filters the nav with `hasPermission(auth.role, …)`, which ignores `isSuperAdmin`, and shows all groups if `getAuthContext` throws. Expose `can` to the client (e.g. `/api/auth/me`) and hide/disable.	as in Problem	M	R

Already sound (reviewed, no action): Meta/WhatsApp/Instagram HMAC over the raw body, constant-time, refused when `META_APP_SECRET` is unset; Telegram per-channel secret; `/api/v1/webhooks/s1` (HMAC before parsing, ±5 min window, per-workspace dedupe); `/api/jobs/run` returns 403 in production without `JOBS_SECRET`; JWT pinned to HS256; bcrypt cost 12; all `$queryRaw` parameterised; no `dangerouslySetInnerHTML` on customer/AI text; media served with `nosniff` and a MIME allow-list without SVG/HTML; every `[id]` route traced scopes by `workspaceId`; CSV export guards formula injection and caps rows; owner-only role changes and last-owner protection; `next` is 14.2.35 (past CVE-2025-29927's 14.2.25 fix). Old audit items still open: F-006 (CSP), XFF trust, `Content-Length`-only body cap, session revocation, `handoffs.resolve` using `claim`, pdf-parse bomb, F-007 (multi-worker unverified).

4.4 Phase 3 — unfinished product pieces (need an owner decision first)

ID	Item	Why it matters
OD-1	Human handoff: either restore creation (human-request / low-confidence / injection / failure → `createHandoff`) or hide `/handoffs` and the "يحتاج موظف" KPI, and rename the nav item.	Today the page is permanently empty and the AI never asks a human, even when the customer demands one. Commit `3c3c4aa` made this deliberate ("answered by the AI itself"); confirm the owner still wants it.
OD-2	Free-text PII to external models (S-07, S-08): internal-only providers, or heuristics.	Owner rule vs. current behaviour.
OD-3	Offers and discounts (L-04, L-05): apply or stop advertising.	Customers are quoted prices the order will not honour.
OD-4	Self-registration policy (S-06).	Public multi-tenant vs. invite-only.
OD-5	`Anthropic` and `Google` appear in the `AI_PROVIDER` enum but **no provider class exists**: selecting them breaks AI replies (`AI_NOT_CONFIGURED`). Build them or remove them from the enum/UI.	
OD-6	The dormant ecosystem code (`integrations/*`, `/api/v1/*`): finish a settings UI + token issuing, or remove. It still runs every worker cycle.	Section 8.
OD-7	TikTok: `connect` returns 501 `CHANNEL_NOT_SUPPORTED`; webhooks exist. Build or remove.	
OD-8	Telegram order notification (`orders/order-service.ts` ≈L266–299) sends a customer's name/phone to a Telegram chat; untested. Rule says no financial approvals from Telegram (this is a notification, but it is customer PII).	

4.5 Phase 4 — UX and product debt (parallelisable)

U-01 Knowledge: restore archived documents; edit/delete FAQs (add `DELETE /api/faqs/[id]`). U-02 Personas: edit a draft version before publishing. U-03 Handoffs/inbox: show the employee's name, not the id. U-04 Campaigns: separate `formError` from per-campaign action errors; key the sending log by campaign. U-05 Step-workflow drafts editable. U-06 Link the "persona preview" copy and guides to the new "جرّبها" flow if wording is stale. U-07 `.env.example` completeness (below). U-08 Remove tracked root clutter: `fluent-*.png` screenshots (tracked although `.gitignore` now ignores them), `tests/helpers/oms-order-parser.ts` (OMS gone).

`.env.example` gaps: missing `HERMES_*`, `ALLOW_MOCK_AI`, `WORKER_BUSY_POLL_MS`, `INTEGRATIONS_ALLOW_PRIVATE_NETWORK`, `AI_WORKSPACE_GATEWAY_KEYS`, `AI_CUSTOM_ALLOW_PRIVATE_NETWORK`, `AI_ALLOW_EXTERNAL_EMBEDDINGS`, `MAX_ORDER_QUANTITY`, `JOB_TIMEOUT_MS`, `ALLOW_SIGNUP` (to be added). It says worker poll 5000 but the code default is 1000. Dead schema entries: `REDIS_URL`, `ANTHROPIC_API_KEY`, `GOOGLE_API_KEY`, `WHATSAPP_TOKEN`, `STORAGE_PROVIDER`, `META_VERIFY_TOKEN` (the code reads `META_WEBHOOK_VERIFY_TOKEN`); `AI_DISABLE_AUTO_HANDOFF` is only in `.env.example`.

4.6 Suggested order of work

1. **Day 1:** S-01, S-02, S-06 (close signup, seed guard), L-01, L-02 — all small, all independent, all with an obvious test. Then S-03, S-04, S-05, D-01.
2. **Next:** L-03, O-01 (backups), S-10, S-09, S-11.
3. **Then** Phase 1 money items in the order L-08, L-04/L-05 (after OD-3), L-07, L-14, then the analytics group L-16…L-20 together (they share files).
4. **Parallel:** Phase 4, and the owner decisions OD-1…OD-8.
5. Re-run the audit prompts (they are in this session's transcript; ask for them) once Phases 0–2 land.

---

5. Architecture map

5.1 Layout

- `src/app/(auth)/` — `login`, `register`. `src/app/(dashboard)/` — 30 pages (22 client components that call `/api/*`, 8 server components); shell and nav filtering in `(dashboard)/layout.tsx` (reads the session, redirects to `/login`). `src/app/api/` — 134 `route.ts` files (≈194 method handlers). **There is no `middleware.ts`** and no server actions: protection is the layout (pages) and `createHandler` (APIs).
- `src/modules/*` — domain services; each takes an injectable `db` (tests pass the fake DB). `src/core/*` — `db/prisma.ts`, `api/handler.ts` (`createHandler`, `handleError`, `ok`), `api/rate-limit.ts` (DB upsert `RateLimitEntry`, memory fallback or fail-closed), `errors.ts`, `env.ts` (zod env schema), `crypto.ts` (AES-256-GCM, constant-time compare), `events/bus.ts` (in-process), `logger.ts` (pino), `analytics/*`. `src/lib/*` — `nav-model`, `nav-redirect`, `nav-search`, `page-guides`, `guided-tour`, `i18n` (`LABELS`, `label()`), `theme`, `provider-labels` (hides the word "Hermes"), `timezones`. `src/components/*` — `app-shell`, `app-sidebar`, `group-tabs`, `inbox/*`, `ui/*` (`empty-state` → `EmptyNext`, `password-input`), `integrations/ui.tsx` (`RiskNote`, `FixNote`), `role-matrix`, `page-guide`, `setup-checklist`, `theme-picker`, `brand-logo`.
- `scripts/` — `worker.ts` (production worker), `scan-secrets.mjs`, `enable-custom-provider.ts`, `staging/{validate-staging.sh, concurrency.mjs, probe-db.cjs}`.
- `prisma/` — `schema.prisma` (≈2,028 lines, 64 models, 40 enums), 24 migrations (`20260922000000_init` … `20261021090000_collection_fields`), `init/01-extensions.sql`, `seed.ts`.
- `tests/` — 99 files; `tests/setup.ts` forces test secrets, removes AI override env vars, installs a fake DNS resolver; `tests/helpers/inmemory-db.ts` is a Prisma stub (array stores, common `where` operators, simulated `include`) — **it does not enforce unique constraints or SQL semantics; only the CI `migrate-check` job touches real Postgres, and it only runs migrations**.

5.2 Modules (responsibility → key files)

`ai` (orchestrator, stages, router, provider, guardrails, privacy-gate, endpoint-guard, prompts, persona-versions, playground-service) · `auth` (`session.ts` JWT cookie `acre_session`, `context.ts` `getAuthContext`, password) · `rbac` (`permissions.ts`, `owner-guard.ts`) · `channels` (facebook/instagram/whatsapp/telegram/tiktok adapters, `outbound.ts` `dispatchOutbound`, `send-policy.ts`, `inbound-job.ts`, `webhook-tx.ts`, retention) · `conversations` (`inbound.ts` `processIncomingMessage`, `threads.ts`) · `customers` · `jobs` (`service.ts`, `handlers.ts`) · `orders` (`order-service`, `draft-service`, `state-machine`, `pricing`, `rules`, `delivery`, `primitives`, `intelligence`) · `products` · `catalog` · `knowledge` (chunker, embeddings, retriever, vector-store) · `media` (`excludeCustomerInbound`) · `automation` (legacy `engine.ts`; workflows `workflow-engine/bridge/service`; `followup-service`) · `campaigns` (runner, service, segments, eligibility) · `sales` (pricing-policy, coach, plan-builder, metrics) · `intelligence` (collection lab) · `handoffs` · `analytics` · `integrations` (P12 leftovers) · `audit`, `feedback`, `members`, `workspaces`, `setup`.

5.3 Request lifecycle

`createHandler(options, fn)` (`src/core/api/handler.ts`) in order: (1) CSRF — for POST/PATCH/PUT/DELETE, if an `Origin` header exists its host must equal `Host`, else 403 `CSRF_REJECTED` (no Origin passes: Meta, server-to-server); (2) `Content-Length` > 110 MB → 413; (3) optional DB rate limit keyed `ip:path` (`rateLimitStrict` fails closed 503); (4) auth — unless `public:true`, `getAuthContext()` loads the user and the **ACTIVE** `WorkspaceMember` fresh from the DB on every request and `auth.require(permission)`; (5) zod `body` / `query`. Errors map: `ZodError` → 422 `VALIDATION_ERROR`; `AppError` subclasses → their code (401/403/404/409/429/502…); anything else → 500 `INTERNAL_ERROR`. 26 routes bypass `createHandler`: analytics (`analyticsRoute` wrapper, `analytics.read` default), webhooks, health, `media/public/[token]`, the Facebook OAuth callback, `/api/v1/*` (`createSystemHandler`, scoped tokens).

5.4 Inbound message pipeline

Webhook route (`api/webhooks/{meta,whatsapp,instagram,telegram,tiktok}`; HMAC / secret verified) → ingest in one transaction (idempotent `WebhookEvent` row + enqueue a job; Facebook uses `process_webhook_event`, others `process_channel_inbound`) → job handler resolves tokens/profile → `processIncomingMessage` (`conversations/inbound.ts`): customer resolve via `ChannelIdentity`, conversation

find/reopen, persist `Message`, publish events, then by `Channel.sendMode`: `COLLECTION_ONLY` → `extract_customer_intel`; `AUTO_REPLY` with `aiState=AI_ACTIVE && aiEnabled` → `process_ai_message` → `processAIMessage` (`ai/orchestrator.ts`): gating (idempotency, state, ordering guard, provider) → extraction (intent/entities, injection screen, order intent, RAG, plan) → response (`sendProtectedText` privacy gate, `validateResponse` guardrails with one regeneration then safe fallback, send, usage log, citations) → `dispatchOutbound` (`send-policy.ts` re-reads `sendMode` at send time; idempotency key `conversationId:sourceMessageId`; per-channel policy incl. the Messenger 24-hour window and WhatsApp window/templates). **The AI path never creates `HumanHandoff` rows.**

5.5 Background jobs and worker

`BackgroundJob` model; 18 job types in `JOB_TYPES` (`jobs/service.ts`): knowledge docs, feedback, media, AI message, summary, webhook/channel inbound, WhatsApp media, automation, follow-ups, analytics aggregate, workflow events/resume, campaign run/tick, attribution validate, product compliance, customer intel. `processPendingJobs`: recover stale (10-min lease) → recover stuck outbound → recover orphaned inbound → atomic claim → run with timeout (`JOB_TIMEOUT_MS`, 120 s) → exponential back-off 30 s…10 min, 3 attempts. Worker (`npm run worker`): loop of `runJobs` (limit 25), `processDueFollowUps`, `runIntegrationScheduler`; poll 1,000 ms (min 250); SIGTERM-safe; no health check (liveness only via the `worker_started`/`worker_heartbeat` log lines). Cron alternative: `POST /api/jobs/run` with `x-jobs-secret`. **The event bus is per process:** the automation and workflow bridges are registered in `scripts/worker.ts`; `/api/jobs/run` registers only the automation bridge; whether events published from Next.js routes reach workflow triggers is **UNVERIFIED**.

5.6 RBAC

Roles `UserRole`: SUPER_ADMIN, OWNER, ADMIN, MANAGER, SALES_AGENT, SUPPORT_AGENT, VIEWER. 46 permissions in `src/modules/rbac/permissions.ts`; `ROLE_PERMISSIONS` (SUPER_ADMIN/OWNER/ADMIN all; MANAGER all except `users.manage`, `workspace.manage`; agents read-mostly). `WorkspaceMember.permissions` can only **add** permissions. Owner-only actions use `requireWorkspaceOwner`. The team page matrix (`components/role-matrix.tsx`) is generated from `ROLE_PERMISSIONS`.

5.7 Data model highlights

Tenancy: `User` (global; `isSuperAdmin`) ↔ `WorkspaceMember` (role, status ACTIVE/INVITED/SUSPENDED, permissions) ↔ `Workspace`; nearly every row has `workspaceId`. Channels: `Channel` (type; `sendMode` AUTO_REPLY | COLLECTION_ONLY), `ChannelAccount` (encrypted credentials). Customers: `Customer`, `ChannelIdentity`, `CustomerMemory`. Conversations: `Conversation` (`aiState` AI_ACTIVE/AI_PAUSED/HUMAN_ACTIVE, `aiEnabled`), `Message` (`outboundIdempotencyKey`). Commerce: `Product*`, `Catalog*`, `Order`, `OrderItem`, `OrderDraft` (one recycled row per conversation), `DeliveryRule`, `DiscountApproval`, `SalesEvent`. AI: `Persona`, `PersonaVersion`, `AISettings`, `KnowledgeDocument/Chunk` (pgvector), `Faq`, `MediaAsset` (category `CUSTOMER_INBOUND`), `Feedback`, `Playground*`, `CustomerIntel*`. Automation/marketing: `Automation(+Version/Execution)`, `FollowUp`, `AudienceSegment`, `Campaign*`, `AttributionTouch`. Ops: `HumanHandoff`, `BackgroundJob`, `WebhookEvent`, `RateLimitEntry`, `AuditLog`. Usage: three overlapping tables (`AIUsageLog`, `WorkspaceUsage`, `Usage`) + `DailyWorkspaceAnalytics`. Legacy P12: `IntegrationConnection/Token/Delivery`, `OmsConnection`, `AgentDraft`, `AgentCallLog`.

5.8 Gotchas

Two Facebook ingest paths (older `process_webhook_event` vs the generic one). Two automation engines in one table (L-14). Hermes naming: internal values `hermes`, `HERMES_*` stay; visible text must go through `src/lib/provider-labels.ts` (no "Hermes" in the UI). Redirect-only pages exist on purpose. `src/lib/guided-tour.ts` (data) and `src/components/guided-tour.ts` (runner) are not duplicates. The Messenger "MessagingPolicy" is `facebook/policy.ts`; there is no class named ChannelSender. Time zones: tests depend on `hourCycle: "h23"`, never `hour12:false`.

---

6. Customer-facing behaviour you must preserve

AI proposes, rules decide, services execute, the database is the source of truth: the AI never sets a price (price always comes from the DB — a test guards injection), never mutates directly, never picks a recipient. `HUMAN_ACTIVE` must mean zero automated replies (currently violated by L-07 — fix, do not relax). Outbound messages are idempotent per `conversationId:sourceMessageId`.

---

7. KPI catalogue — how each number is computed today (owner rule: every KPI states its rule)

All counts are per workspace. Range is `[start, end)` with day boundaries in the time zone the user picks (default UTC — L-19). "Confirmed set" = order status CONFIRMED, PROCESSING, OUT_FOR_DELIVERY or DELIVERED, judged by the **current** status. Money = sum of `Order.total` (= items − discount + delivery fee), **no tax**, and currently **summed across currencies (L-08)**.

Dashboard: محادثات = conversations created in range · طلبات = all orders created in range · عملاء جدد = customers created in range · **التحويل** = orders created in range in the confirmed set ÷ conversations created in range × 100 (different populations — L-16) · رسائل الذكاء = AI usage-log rows (calls, including failed) · يحتاج موظف = handoffs created in range still OPEN (always 0 in production — OD-1) · طلبات/إيرادات مؤكدة and مُسلَّمة = orders created in range in the confirmed set / DELIVERED, and their `total` sum · نشطة = conversations OPEN right now (not range-limited) · رسائل واردة/صادرة = messages by direction in range (notes included here, excluded in trends) · استدعاءات فاشلة = usage rows with `success=false` · توكنز = prompt + completion tokens · التكلفة التقديرية = sum of known `costUsd` (null only if every call unknown; a partial sum shows without a warning) · إجمالي التحويلات = handoffs created in range · متوسط زمن الحل = mean(`resolvedAt - createdAt`) over handoffs with `resolvedAt` (includes cancelled) · تنفيذات/ناجحة/فاشلة/متجاوزة = automation execution rows by status (skipped checks count as executions).

Reports tab: *Funnel* (محادثات → مسودات → جاهزة → مؤكدة → مسلَّمة) = conversations created; drafts created whose current state is not EMPTY; drafts in READY/CONFIRMING/CONFIRMED/CONVERTED (current state — L-17); confirmed orders; delivered orders; each rate = stage ÷ previous, null when the denominator is 0. *Comparison %* = (current − previous) ÷ previous × 100, «جديد» when previous is 0. *Conversations*: first-response time = minutes from first inbound to first outbound (AI, human or automation) per new conversation, notes/deleted excluded, unanswered excluded; resolution time = `updatedAt - createdAt` for RESOLVED/CLOSED (L-21). *Sales*: counts by current status; قيمة مؤكدة = sum of `total` over the confirmed set; average = that ÷ confirmed count; offer acceptance = OFFER_ACCEPTED ÷ OFFER_SHOWN events in range (no dedupe — L-23). *Products*: units = sum of item quantity over confirmed orders created in range; revenue = item `subtotal` (price × qty, **before** discount and delivery — will not match قيمة مؤكدة). *Agents*: assigned conversations, human outbound replies, median first response, linked orders, handoffs, approved discounts (audit `sales.discount_approved`). *AI*: calls/success/failure, tokens in/out, average `latencyMs`, cost. *Campaigns*: status of all campaigns (not range-limited), distinct recipients, SENT (platform accepted), confirmed delivered (DELIVERED/READ). *Automation*: completed/failed per rule, success = completed ÷ (completed + failed). *Trends*: one row per **UTC** day, only rows with status OK (L-18). **CSV export** uses the same functions as the screen; the "Excel" button actually downloads CSV.

---

8. Integrations and external systems

Status key: **MOCK** built and tested with mocks only · **DORMANT** backend exists, nothing can configure it · **REMOVED** · **NOT BUILT**. Nothing below has been verified live.

8.1 Messaging channels

Channel	Our endpoints	Auth	Setup	Status
Messenger + Facebook comments	`GET/POST /api/webhooks/meta`; OAuth `/api/channels/facebook/{connect,callback,select-page,disconnect}`; `/api/comments/facebook/*`; Graph `v21.0`	`X-Hub-Signature-256` HMAC with `META_APP_SECRET`; GET challenge with `META_WEBHOOK_VERIFY_TOKEN`	Env: `META_APP_ID`, `META_APP_SECRET`, `META_WEBHOOK_VERIFY_TOKEN` (+ optional `META_REDIRECT_URI`, `META_GRAPH_VERSION`). OAuth scopes: `pages_show_list, pages_messaging, pages_manage_metadata, pages_read_engagement`. UI: `/channels`	MOCK; live NOT VERIFIED
Instagram	`GET/POST /api/webhooks/instagram`; `/api/comments/instagram/*`	Same app-secret HMAC	Account id + token pasted by hand (no OAuth)	MOCK; Meta app review blocked
WhatsApp Cloud API	`GET/POST /api/webhooks/whatsapp`; inbound media download	Same `META_APP_SECRET` HMAC (must be the same Meta app)	Phone-number id + permanent token pasted per channel; approved templates needed for campaigns	MOCK; no live number
Telegram	`POST /api/webhooks/telegram`; `setWebhook` auto-called when `APP_URL` is https	Per-channel secret header, stored encrypted	Bot token in the UI; optional `TELEGRAM_BOT_TOKEN` + `TELEGRAM_ORDER_CHAT_ID` for order notifications	MOCK
TikTok	`/api/webhooks/tiktok`	Per-channel secret	—	connect returns 501 (NOT BUILT)

RISK Meta permissions: comment reply/hide normally also needs `pages_manage_engagement`, and Instagram needs `instagram_basic`, `instagram_manage_messages`, `instagram_manage_comments`; none are requested by the OAuth flow (exact Meta requirements **UNVERIFIED**). **FIX** Confirm in the Meta developer console before App Review; allow lead time for review.

8.2 AI providers (`src/modules/ai/provider.ts`, `router.ts`; settings `/settings/ai`, `/api/ai/settings`, `/api/ai/providers/test`)

- **openai / openrouter**: platform keys via env (`OPENAI_API_KEY`, `OPENROUTER_API_KEY`, `OPENROUTER_BASE_URL`); the collection lab also calls OpenRouter directly (`INTEL_MODEL`) — S-07.
- **custom / internal** (self-hosted, e.g. GLM): per-workspace `customBaseUrl` + encrypted key, SSRF-guarded by `ai/endpoint-guard.ts` (but see S-09, S-10). A platform key is refused on a workspace URL unless `AI_WORKSPACE_GATEWAY_KEYS=1`.
- **hermes** ("الوكيل الذكي" in the UI): OpenAI-compatible gateway on the owner's server; env `HERMES_BASE_URL`, `HERMES_API_KEY`, `HERMES_MODEL`, `HERMES_ALLOW_PRIVATE_NETWORK`; redirects not followed; delivery "external" so PII is masked — **but see S-02**.
- **anthropic / google**: in the enum, **no provider class** (OD-5).
- **mock**: only under `NODE_ENV=test`, `ALLOW_MOCK_AI`, or non-production with nothing configured; production fails closed.
- Privacy gate: `ai/privacy-gate.ts` (masking) covers orchestrator, playground, summaries; **not** the collection lab (S-07) and not free text (S-08).

8.3 Zaki ecosystem (sibling systems)

Direction and contract are those of the old P12 design (`docs/INTEGRATIONS.md`, whose OMS and Hermes-door parts are now false). What exists in code today:

System	Direction · endpoints	Auth	Status
Zaki OMS (`MKory18/Zaki-ai-CRM`)	was: OMS → us `POST /api/webhooks/oms/{key}`; us → OMS `POST {OMS}/api/v1/orders` (the OMS "door" was never built on the OMS side: `docs/OMS-DOOR-V1.md`)	was: `sha256=` HMAC over `ts.body`, ms timestamp	**REMOVED** (`3c3c4aa`). Only the shared signing helper `integrations/signing.ts` and a Telegram order notification remain. The OMS's own "AI order intake" that posts order text to OpenRouter is flagged in `AGENTS.md` (status not checked from this repo).
Media Buyer (الميديا باير)	MB → us `GET /api/v1/capacity`; us → MB `capacity.alert` to `{MB}/api/v1/webhooks/replies`	Inbound Bearer `zr_mb_…`, scope `capacity.read`, SHA-256 hash, 90-day expiry; outbound `X-Zaki-Timestamp` (s) + `X-Zaki-Signature` HMAC-SHA256 hex over `ts.body`	MOCK + DORMANT
Clipper (منصة الكليبر)	Clipper → us `POST/GET /api/v1/retarget-campaigns` (Idempotency-Key); us → Clipper `conversation.coded`, `retarget.result`, `opt_out`, and `GET {CLP}/api/v1/codes/{code}`	Bearer `zr_clp_…` + HMAC	MOCK + DORMANT
Finance (المالية)	us → `POST {FIN}/api/v1/usage-costs` (key `replies-usage-<tag>-<day>`)	Bearer	MOCK + DORMANT
System 1 (سيستم 1 — compliance)	us → `GET {S1}/api/s1/v1/products/{ref}/compliance`; S1 → us `POST /api/v1/webhooks/s1?ws={slug}` (`compliance.updated`)	Bearer; inbound HMAC with the connection secret, ±5 min	MOCK + DORMANT
Crisis (الأزمات), Tasks (المهام), Workspace (مساحة العمل)	us → `/api/v1/alerts`, `/tasks`, `/ideas`	Bearer	MOCK + DORMANT; those systems are not built/deployed
Hermes bridge / agent door	was `GET /api/agent/tools`, `POST /api/agent/call`	`zr_hrm_…`	**REMOVED**

All "DORMANT": `createIntegrationToken` and `saveIntegrationConnection` are called only from tests, so production has no way to create a token or a connection without writing to the DB. The worker still evaluates them each cycle (harmless, but dead weight — OD-6). Any new system must follow the signed-outbox pattern and include the workspace in every idempotency key.

---

9. Environment, running, deploying, going live

9.1 Run it locally

```
cp .env.example .env      # fill JWT_SECRET and ENCRYPTION_KEY (openssl rand -hex 32), keep DATABASE_URL consistent
docker compose up -d postgres
npm install
npx prisma migrate dev
npm run db:seed           # DEMO ONLY: admin@demo.local (password is in prisma/seed.ts); never in production
npm run dev               # the owner's dev server in this session ran on port 3260
npm run worker            # separate process; needed for AI replies, sends, follow-ups
```

Full stack: `docker compose up -d --build` (app + worker + `pgvector/pgvector:pg16`); compose requires `POSTGRES_PASSWORD`. Windows note: `prisma generate` fails with EPERM if a dev server holds the engine DLL — stop it before `npm run build`.

9.2 Environment variables (from `src/core/env.ts`; required = app will not start)

Required: `DATABASE_URL`, `JWT_SECRET` (≥32), `ENCRYPTION_KEY` (≥32). Production-required in practice: `APP_URL` (public https, no trailing slash — OAuth, Telegram webhook, logout), `JOBS_SECRET` (else `/api/jobs/run` is 403), one real AI provider + key, `META_APP_ID`, `META_APP_SECRET`, `META_WEBHOOK_VERIFY_TOKEN` for Meta, `STORAGE_DIR=/app/.data/storage` (persistent volume), `POSTGRES_PASSWORD` (compose) — **RISK** the compose default `DATABASE_URL` still says `postgres:postgres`, which no longer matches the required strong password: set `DATABASE_URL` explicitly. Optional: `WORKER_POLL_INTERVAL_MS` (1000), `WORKER_BUSY_POLL_MS` (250), `JOB_TIMEOUT_MS`, `LOG_LEVEL`, retention `WA_MEDIA_RETENTION_DAYS` (180) / `WEBHOOK_PAYLOAD_RETENTION_DAYS` (30) (`0` = off), `MAX_ORDER_QUANTITY` (100), model overrides (`CLASSIFICATION_MODEL`, `EXTRACTION_MODEL`, `RESPONSE_MODEL`, `VISION_MODEL`, `SUMMARY_MODEL`, `INTEL_MODEL`, `EMBEDDING_MODEL`, `EMBEDDING_DIMENSIONS`), `AI_ALLOW_EXTERNAL_EMBEDDINGS`, `AI_REQUEST_TIMEOUT_MS`, `FACEBOOK_SEND_TIMEOUT_MS`, `HERMES_*`, `AI_CUSTOM_ALLOW_PRIVATE_NETWORK`, `AI_WORKSPACE_GATEWAY_KEYS`, `INTEGRATIONS_ALLOW_PRIVATE_NETWORK`, `ALLOW_MOCK_AI`, `ORDERING_GUARD_FRESH_MINUTES`, `ORPHAN_MAX_AGE_HOURS` (value UNVERIFIED), `TELEGRAM_BOT_TOKEN`, `TELEGRAM_ORDER_CHAT_ID`. **Never commit real values**; `npm run scan:secrets` guards this.

9.3 The running local stack

Docker project `airesponse` (app `:3250`, worker, postgres `127.0.0.1:5433`) was built from the Documents copy: app image 2026-10-21 22:29, worker image 21:58 (so app and worker run slightly different code); both predate the six restructure commits. Volumes `airesponse_pgdata`, `airesponse_storage` persist as long as the compose project name stays `airesponse`. To update: rebuild app and worker from this tree (no new migrations; `package.json` changed — driver.js — so a rebuild, not a restart). Unrelated containers on the machine: `salesflow-app` (the OMS, `127.0.0.1:3100`), `mediabuyer-db`, `zaki-workspace-db-1`, `zk-livekit-dev`.

9.4 Can we run it for real now? (answer to the owner's question)

For the owner's own controlled use: yes, very soon. One workspace, signup closed, seed never run, a strong `POSTGRES_PASSWORD`, `JOBS_SECRET` set, HTTPS in front, backups on. That needs S-06 plus a day of ops work (O-01), nothing else. **For real customer traffic and multiple stores: not until Phase 0 is done** (S-01, S-02, S-03, S-04, S-05, L-01, L-02, L-03). Reason: the two critical defects let any stranger take over any account or steal the server AI key, and the order parser can cancel or create orders from innocent sentences. **Long lead-time items that should start now, in parallel:** Meta App Review (advanced access for the messaging permissions; Live mode), a Meta-verified WhatsApp Business account with approved message templates, and a first real end-to-end test on a staging stack (never done: `docs/COOLIFY-STAGING.md` says "STAGING = NOT VERIFIED").

9.5 Go-live checklist (ordered)

1. Infrastructure: VPS or Coolify, repo `docker-compose.yml`, **pgvector image** (the baseline migration runs `CREATE EXTENSION vector`).
2. Env vars (9.2). 3. Migrations: automatic on app and worker start (`prisma migrate deploy`); 24 migrations. 4. Worker container running (watch the `worker_heartbeat` log). 5. Persistent volume for storage (local provider only; no S3). 6. **Backups** (database + storage, off-host) and a restore drill — none exist. 7. Domain + HTTPS (session cookie is `secure` only when `NODE_ENV=production`); health check `GET /api/health` (503

only when the DB is down). 8. Meta app: webhook URLs `{APP_URL}/api/webhooks/{meta,instagram,whatsapp}` with the verify token; OAuth redirect `{APP_URL}/api/channels/facebook/callback`; switch to Live. 9. WhatsApp: permanent system-user token + phone-number id pasted in `/channels`; same Meta app. 10. Telegram: bot token in the UI. 11. First owner: **public self-signup** at `/register` (`POST /api/auth/register`, 5/min) — close it afterwards (S-06); later staff join by invite. **Do not run `db:seed` in production.** 12. Run `scripts/staging/validate-staging.sh` and `concurrency.mjs` against the real stack and record the results in `docs/PROGRESS.md`.

9.6 Still unverified (carried over from the audits)

Staging on a real stack, Playwright/HTTP end-to-end, load baseline, backup/restore, several workers at once, live Meta/WhatsApp/Telegram/AI-provider calls, the sibling systems and their contracts, real mobile devices. A local Docker stack now exists but its results were never recorded.

---

10. How to work in this repository

Gates before every commit (all must pass): `npm run typecheck` · `npm run lint` · `npm test` (≈1,533 tests, in-memory DB, no Postgres needed) · `npm run scan:secrets` · `npm run build`. In an environment without the Prisma engine, one `PrismaClientInitializationError` per test file is expected; CI does not show it. CI (`.github/workflows/ci.yml`, Node 22): job `verify` (the five gates with dummy env) and job `migrate-check` (`prisma migrate deploy` on real pgvector Postgres — it does **not** check schema drift; adding that is a good small task).

Process. New branch from an up-to-date `main`; failing test first; fix; gates; PR; wait for green CI; merge. Never push to `main`. Schema change = additive migration only (no drops, no type changes). Any new dashboard page needs: a `NAV_GROUPS` entry, `PAGE_KEYWORDS` (`src/lib/nav-search.ts`) and a `PAGE_GUIDES` entry with a valid "next" page — or `tests/nav-structure.test.ts`, `nav-search.test.ts`, `page-guides.test.ts` fail. Any displayed enum needs an Arabic `LABELS` entry (`tests/labels-arabic.test.ts`). Any new media query must go through `excludeCustomerInbound()`. Any new idempotency key includes the workspace. Any new secret field uses `PasswordInput`. Never write "Hermes" in visible text. Theme colours only from CSS variables.

Communication with the owner. Jordanian Arabic, short, no jargon; written deliverables as `.docx` + PDF; risks in red with the fix in orange.

---

11. Tools, skills and open-source used

- **driver.js 1.9.0** (MIT, pinned exactly) — guided tour. No other runtime dependency was added.
- **Existing stack kept:** Next 14.2.35, React 18, Prisma 5.22, zod 3, jose, bcryptjs, exceljs, pdf-parse 1.1.1, pino, Tailwind 3, Vitest 2.
- **Skills on the owner's machine** (in `~/.claude/skills`, not in the repo — copy them if the new account needs them): `zaki-image-prompts` (image prompts for the Zaki system; deliver prompts as one Word file), `crm-oms-guard` and `zaki-mediabuyer-guard` (architecture guards for the **other** repositories — the OMS and the Media Buyer — not for this one), plus art/audio prompt skills for the owner's other projects. For this repo the only rules file is `AGENTS.md`.
- **Process tooling used in this session:** GitHub CLI (`gh`) logged in as `MKory18` on the machine (the push to the fork used the `iahmed30004000-wq` remote), Docker Desktop, the Claude Code desktop app (browser pane for visual checks), five read-only review agents for the audit in section 4. The audit prompts can be re-run after the fixes land.
- **Not installed / not used:** no MCP connectors or plugins were added to the project; `opencode.json` (tracked) configures Playwright MCP for GLM only.

---

12. Quick reference: verified facts and how they were checked

- `3c3c4aa` deleted OMS, agent door, integrations UI: `git show --stat 3c3c4aa` (and the directories are absent).
- `parseConfirmation` misreads: ran the function with `npx tsx` on four strings.
- `resetMemberPassword` and `inviteMember`: read `members/service.ts` and the route; no status or cross-workspace check present.
- Hermes key path: read `ai/router.ts` hermes branch; `verifySessionToken` vs the `kind` checks in `oauth.ts`: read both.
- `mkory18/main` = `2052c26`: `git fetch mkory18` then `git log`.
- Everything marked **R** was reported by a reviewer that read the code path; re-confirm with the regression test in the table before fixing.

End of handover.